

# RiskWaiver360

---

GRC Process Exception &  
Policy Waiver Management Platform

---

**TEAM:** S Abhilash · Rajath S

**INSTITUTION:** RVCE (RV College of Engineering), Bengaluru

**TRACK:** Policy Governance & Risk Management

**YEAR:** 2026 · Societe Generale Hackathon



GRC

## Where Do Policy Exceptions Live Today?

- Scattered across email threads and Slack messages
- Tracked informally in spreadsheets with no lifecycle control
- Expired exceptions left active — never revoked
- No central visibility for security teams or auditors
- Access granted "temporarily" becomes permanent without review
- Hidden attack paths grow where exceptions are forgotten

## Audit Risk

No evidence trail for expired exceptions

## Security Gaps

Expired firewall & access exceptions still active

## Compliance Drift

Policies waived without proper justification

01

## Orphaned Access

User left the org — access exception never revoked. Account remains open.

02

## Overlapping Waivers

Two exceptions approved for the same asset and policy. No one noticed.

03

## Conflicting Approvals

One approver approved; another rejected. System shows both records.

04

## Long-Running Temp Access

"Temporary" admin access from 18 months ago — still active, never reviewed.

05

## Risk Accumulation

15 exceptions on one critical asset. Combined exposure is extremely high.

06

## Audit Failure

Auditor requests evidence. No justification, no review record, no expiry trail.

## CENTRALIZED

Single source of truth for all exceptions

## RISK-SCORED

Quantitative scoring, not guesswork

## LIFECYCLE-TRACKED

From intake to expiry, every step recorded

## AUDIT-READY

Evidence-backed, exportable reports

## Exception Lifecycle Flow

1

Structured  
Intake

2

Security  
Review

3

Approver  
Decision

4

Continuous  
Monitoring

5

Audit  
Evidence

*"Turn scattered exceptions into governed, scored, lifecycle-tracked decisions."*

## PRESENTATION LAYER

- › React 18 + Vite · Role-Based Workspaces
- › 4 Role Views: Requester / Reviewer / Approver / Auditor

## API LAYER

- › Node.js + Express REST API · Port 4000
- › Routes: Exceptions · Approvals · Alerts · Conflicts · Audit

## DATA & SERVICES LAYER

- › JSON Flat-File Storage (Demo) · 600 Exception Records
- › Services: Risk Scoring · Alert Engine · GRC Intelligence · Audit

Engines:

Risk Scoring

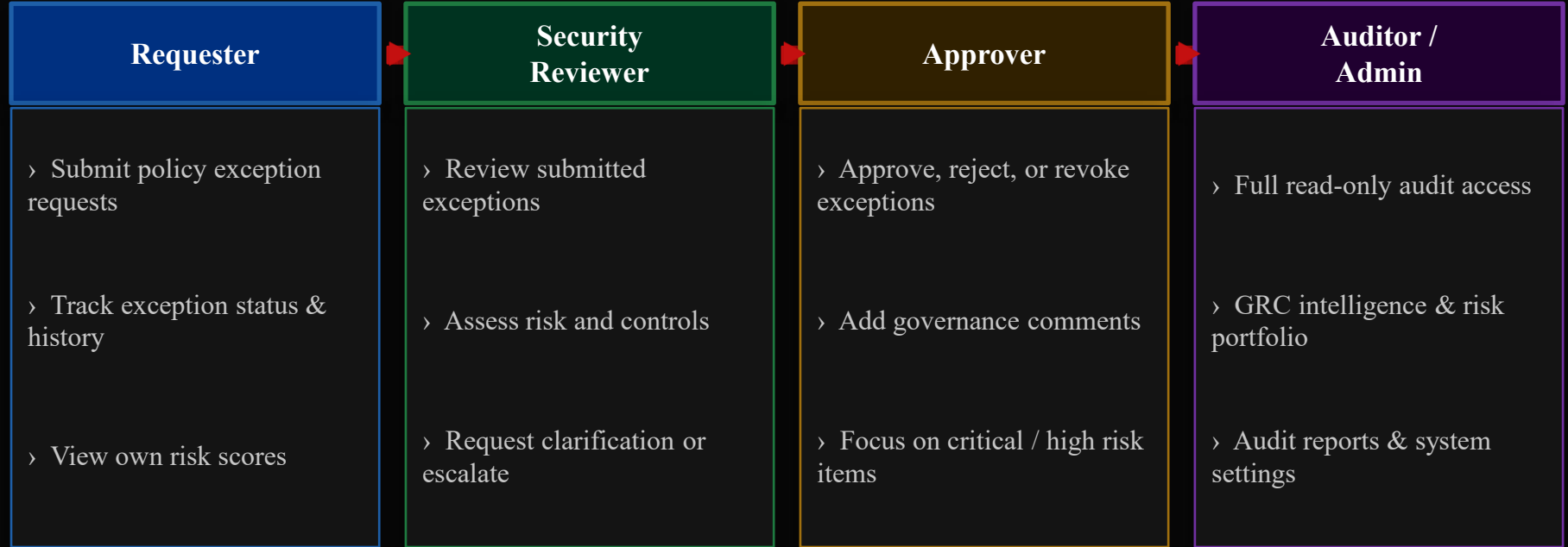
Alert Engine

GRC Intelligence

Audit Report

# Role-Based Workflow — Four Workspaces

6/12



Exception Status Flow:



*Every action is timestamped and stored in the exception history for audit evidence.*

## 01 Exception Risk Register

Filterable registry of all 600 exceptions. Search, filter by dept, status, risk, type.

## 02 Structured GRC Intake

Validated intake form: exception type, asset, policy, CIA, owner, justification.

## 03 Security Review Queue

Prioritized queue for reviewers. Checklist, risk bands, action buttons.

## 04 Exception Evidence File

Full exception detail: lifecycle, approvals, history, GRC conflicts, risk score.

## 05 Risk Scoring Engine

Rule-based score (0-100). Type + Asset + Duration + Expiry + Review - Controls.

## 06 Continuous Monitoring

682 alerts: overdue, expiring soon, orphaned owner, missing controls, review due.

## 07 GRC Intelligence Center

Detects overlaps (90), duplicates (59), conflicts, and risk accumulation hotspots (37).

## 08 Audit-Ready Reports

Department & risk breakdown, lifecycle analysis, printable evidence packs.

## 09 Settings & Roadmap

Dataset stats, scoring config, role matrix, limitations, and production roadmap.

# Risk Scoring Engine — Rule-Based & Explainable

8/12

$$\text{Risk Score} = \text{Type Weight} + \text{Asset Criticality} + \text{Duration Penalty} + \text{Expiry Status} + \text{Review Penalty} + \text{Owner Status} - \text{Control Bonus}$$

## Scoring Factors

|                   |             |                                                |
|-------------------|-------------|------------------------------------------------|
| Exception Type    | 20 – 35 pts | Admin Access 30, Firewall 25, Encryption 35... |
| Asset Criticality | 10 – 30 pts | Critical asset adds 30 pts                     |
| Duration Penalty  | 0 – 15 pts  | >90 days: +10, >180 days: +15                  |
| Expiry Status     | 0 – 20 pts  | Overdue: +20, Expiring soon: +10               |

|               |            |                                  |
|---------------|------------|----------------------------------|
| Review State  | 0 – 10 pts | Never reviewed: +10, Overdue: +5 |
| Owner Status  | 0 – 10 pts | Inactive / unassigned owner: +10 |
| Control Bonus | 0 – 15 pts | Strong compensating control: –15 |

Low 0–30

Medium 31–59

High 60–79

Critical 80–100

*Score Range 0–100 · Rule-based · Explainable · Audit-friendly*



## Continuous Monitoring Alerts

**682** **Total Active Alerts**  
Across all monitored exceptions

**333** **Critical Risk**  
Risk score  $\geq 80$  — immediate attention

**156** **Overdue Exceptions**  
Past expiry date, still active

**127** **Review Overdue**  
Not reviewed in 90+ days

**24** **Missing Controls**  
No compensating control documented

**23** **Expiring Soon**  
Expiry within 14 days

**19** **Orphaned Owner**  
Owner is inactive or unassigned

## GRC Intelligence Center

**186** **Total GRC Findings**  
Detected across 600 exceptions

**27** **Critical Accumulation**  
Assets with stacked risk  $\geq 1500$

**90** **Overlapping Exceptions**  
Same asset + policy, concurrent dates

**59** **Duplicate Waivers**  
Same dept + asset + type, similar justification

**0** **Conflicting Approvals**  
No governance conflicts detected

**37** **Risk Hotspots**  
Assets accumulating high combined risk

## Compliance Frameworks

### NIST AC-2

Account Management — exception lifecycle & access control tracking

### NIST PL-4

Rules of Behavior — policy waiver governance and documentation

### GDPR Article 25

Data Protection by Design — privacy risk captured in exception intake

### CIS Control 1.1

Inventory of Assets — asset-mapped exception registry

### ISO 27001 A.9

Access Control — enforces review, expiry, and approval workflows

## CIA Impact Classification

C

### Confidentiality

Data disclosure risk if exception is misused

I

### Integrity

Data accuracy at risk from unauthorized changes

A

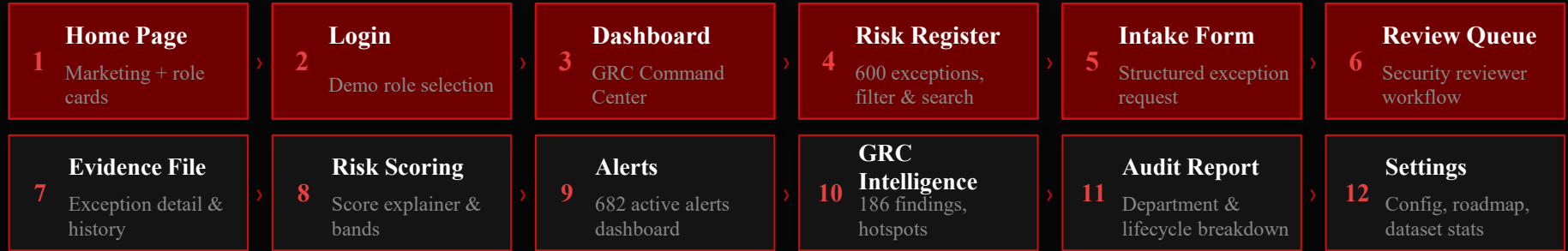
### Availability

Service disruption risk if exception expires

M

### Multiple

Exceptions impacting more than one CIA dimension



[ Insert Screenshot ]

*Dashboard — GRC Command Center*

[ Insert Screenshot ]

*GRC Intelligence Center — Findings*

## Current Prototype

- localStorage-based demo authentication (no session security)
- JSON flat-file storage (not production-grade)
- No backend RBAC — roles enforced frontend only
- Email notifications are simulated (not sent)
- PDF export via browser print (not server-generated)
- Captcha is frontend-only, no CSRF protection
- 30 demo system users only (not a real user directory)

## Production Roadmap

- SSO / OIDC integration (Okta, Azure AD)
- Backend RBAC with JWT-secured routes
- PostgreSQL or MongoDB for data persistence
- ServiceNow / Jira / CMDB integration
- IAM / Active Directory owner resolution
- Real PDF audit report generation
- AI-assisted risk scoring (future scope only)

*"RiskWaiver360 turns scattered exceptions into centralized, risk-scored, lifecycle-tracked, audit-ready governance decisions."*